

Threat Modeling di una Agentic Filler Pipeline per Digital Human in tempo reale

Progetto per il corso di
Sicurezza delle Architetture Data Intensive (6 CFU)

Prof. Ernesto Damiani

Università degli Studi di Milano
Corso di Laurea Magistrale in Sicurezza Informatica

Studenti: Marta Finazzi
Alessio Bonora

Luglio 2026

Indice

1	Abstract	1
2	Introduzione e obiettivi	1
2.1	Contesto	1
2.2	Perché il sistema è agentico	1
2.3	Obiettivi dell'analisi	2
3	Scope e metodologia	2
3.1	Oggetto dell'analisi	2
3.2	Processo di threat modeling	2
4	Descrizione della pipeline agentica	3
4.1	Architettura della pipeline agentica	3
4.2	Ruoli, azioni e privilegi attesi	4
4.3	Fast-Brain Agent	4
4.4	Deep-Brain Agent	4
4.5	Orchestrazione e stati	5
5	Data Flow Diagram e trust boundary	5
5.1	DFD di livello 0	5
5.2	DFD di livello 1	5
6	Asset Model	6
6.1	Proprietà di sicurezza considerate	6
6.2	Data Assets	7
6.3	Model Assets	10
6.4	Considerazioni sulla classificazione	13
7	Identificazione delle minacce	14
7.1	STRIDE-AI applicato direttamente alle threat concrete	14
7.2	Applicabilità dell'OWASP Top 10 for Agentic Applications	15
8	Risk prioritization	16
8.1	Criteri	16
8.2	Matrice qualitativa	16
8.3	Priorità dei rischi principali	17
9	Scenari di minaccia prioritari	17
9.1	Scenario 1 — Goal hijack del Fast-Brain	17
9.2	Scenario 2 — Feedback poisoning persistente	18
9.3	Scenario 3 — Identity and privilege abuse tra agenti	18
9.4	Scenario 4 — Tampering e replay dei messaggi inter-agent	19
9.5	Scenario 5 — Voice clone abuse e human-agent trust exploitation	19

10 Controlli secondo le sette precauzioni	20
10.1 Precauzione 1 — Least Agency	20
10.2 Precauzione 2 — Guardrail deterministici e HITL	20
10.3 Precauzione 3 — Sandboxing e controllo granulare degli accessi	20
10.4 Precauzione 4 — Audit trail completo e immutabile	21
10.5 Precauzione 5 — Supply chain control	21
10.6 Precauzione 6 — Continuous execution monitoring	21
10.7 Precauzione 7 — Audit periodici ispirati ad AIVSS	21
11 Secure architecture proposal	22
11.1 Fail-safe behavior	22
12 Trade-off sicurezza–latenza	23
13 Piano di validazione sperimentale	23
13.1 Esperimento A — Fast-Brain security harness	23
13.2 Esperimento B — Feedback poisoning simulation	24
13.3 Esperimento C — Sicurezza dei messaggi inter-agent	24
14 Rischio residuo	25
15 Limitazioni	25
16 Conclusioni	26
A JSON Schema semplificato del Fast-Brain	26
B Formato sicuro del messaggio inter-agent	27
C Matrice di tracciabilità	27

1 Abstract

Questo progetto presenta il threat modeling di una pipeline agentica progettata per ridurre la latenza percepita durante l'interazione con un digital human. L'architettura adotta un modello *dual-brain*: un **Fast-Brain Agent** produce rapidamente un filler verbale e un trigger gestuale, mentre un **Deep-Brain Agent** elabora la risposta principale tramite LLM, RAG e memoria contestuale. I due percorsi sono eseguiti in parallelo e coordinati da un orchestratore che gestisce priorità, transizione audio-video, fallback e sincronizzazione.

L'analisi è deliberatamente centrata sulla natura **agentic** del sistema. Come indicato per questa traccia, non viene applicata una FMEA: le minacce sono identificate direttamente a partire da asset, agenti, azioni, tool, memorie, identità e trust boundary. Il processo combina **STRIDE-AI**, le proprietà di sicurezza CIA³-R e l'**OWASP Top 10 for Agentic Applications 2026**. La relazione definisce lo scope, esplicita le assunzioni architetturali, costruisce un attacker model, valuta l'applicabilità dei rischi OWASP e approfondisce cinque scenari prioritari: goal hijack del Fast-Brain, poisoning persistente del feedback, abuso di identità e privilegi tra agenti, tampering/replay dei messaggi inter-agent e sfruttamento della fiducia tramite voice cloning.

Le mitigazioni sono organizzate secondo le sette precauzioni discusse nel corso: Least Agency, guardrail deterministici e Human-in-the-Loop, sandboxing e controllo granulare degli accessi, audit trail immutabile, controllo della supply chain, monitoraggio continuo e audit periodici ispirati ad AIVSS. Il risultato è una proposta di architettura sicura che preserva il requisito di bassa latenza mediante controlli sincroni deterministici, fallback fail-safe e controlli più costosi spostati fuori dal percorso critico.

2 Introduzione e obiettivi

2.1 Contesto

La traccia considera una pipeline per digital human nella quale il percorso STT–LLM–TTS–Lip-Sync-streaming presenta una latenza incompatibile con una conversazione percepita come naturale. Il requisito di progetto assume un tempo percepito di prima risposta inferiore a circa 800 ms e riporta, nello stato iniziale della pipeline, latenze che possono arrivare a decine di secondi. Per mascherare l'attesa viene introdotto un ciclo agentico di filler contestuali, più credibili di una semplice animazione statica o di una frase ripetitiva [1].

L'istanza applicativa usa un avatar con personalità coerente, voce clonata e comportamento gestuale. La personalità allegata al progetto descrive una figura anziana emiratina, con stile materno, uso del dialetto locale e riferimenti a rimedi tradizionali. Tali caratteristiche aumentano il realismo, ma anche il potere persuasivo dell'output e quindi la rilevanza di autenticità, safety e tutela della fiducia dell'utente [4, 5].

2.2 Perché il sistema è agentico

Secondo il materiale del corso, un sistema agentico combina inferenza e azione, può invocare servizi esterni, comunicare tramite memoria condivisa o persistente e coordinarsi con altri agenti senza supervisione umana passo per passo [2]. La pipeline analizzata soddisfa tali caratteristiche perché:

- il Fast-Brain interpreta un input parziale e decide filler, tono e trigger gestuale;
- il Deep-Brain recupera contesto dal RAG e genera la risposta sostanziale;
- l'orchestratore prende decisioni su fork, ordine di riproduzione, timeout, fallback e stitching;
- il sistema invoca servizi di STT, TTS, generazione video, voice cloning e lip-sync;

- feedback e memoria possono influenzare le interazioni future;
- l'output del Fast-Brain viene emesso prima che il percorso principale sia completato.

2.3 Obiettivi dell'analisi

Gli obiettivi sono:

1. definire con precisione architettura, scope e assunzioni;
2. identificare gli asset Data, Model e gli asset agentici di supporto;
3. individuare minacce concrete senza passare da una FMEA;
4. classificare le minacce tramite STRIDE-AI e OWASP Agentic;
5. prioritizzare i rischi in base a likelihood, impact e amplificatori agentici;
6. proporre controlli coerenti con le sette precauzioni del corso;
7. progettare una secure architecture compatibile con il vincolo real-time;
8. definire un piano sperimentale riproducibile senza inventare risultati non misurati.

Scelta metodologica. La FMEA non viene applicata. Il threat model parte direttamente da asset, agenti, trust boundary, identità, memorie, tool e azioni. La FMEA rimane appropriata per analizzare guasti e failure mode di pipeline AI tradizionali, ma non è richiesta per questa traccia agentica.

3 Scope e metodologia

3.1 Oggetto dell'analisi

L'oggetto è la **pipeline agentica dual-brain** che maschera la latenza della generazione audiovisiva. Il Deep-Brain usa internamente il percorso RAG e i servizi multimediali; tali componenti sono inclusi soltanto nella misura in cui rappresentano memorie, tool o superfici d'attacco raggiungibili dagli agenti.

Sono inclusi:

- input vocale o testuale, VAD e streaming STT;
- Fast-Brain e Deep-Brain;
- orchestratore e messaggi inter-agent;
- RAG, memoria di sessione, eventuale memoria persistente e feedback;
- TTS filler, TTS principale, voice cloning, generazione video e lip-sync;
- identità di servizio, credenziali, policy, log e artefatti intermedi;
- output audio-video verso l'utente.

Sono fuori scope, salvo che vengano introdotti in implementazioni future:

- code interpreter, shell e valutazione dinamica di codice generato;
- accesso dell'agente a sistemi amministrativi esterni;
- modifica autonoma di risorse cloud o database operativi;
- strumenti non descritti nella traccia.

3.2 Processo di threat modeling

Il processo adottato è:

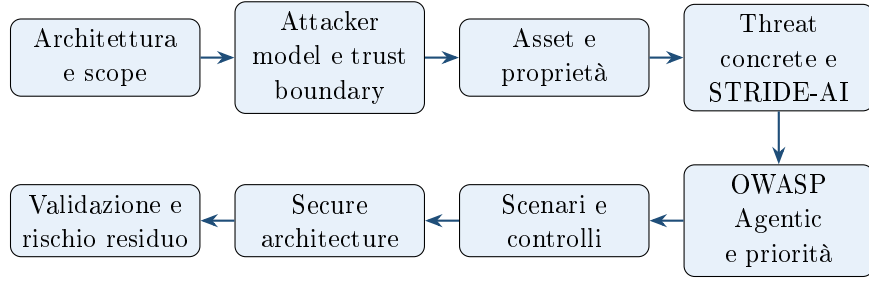


Figura 1: Processo adottato per la pipeline agentic.

La metodologia STRIDE-AI mantiene un approccio asset-centered e adatta le categorie classiche di STRIDE agli asset AI/ML [6, 7]. Per i rischi specifici degli agenti viene usata la tassonomia OWASP Agentic 2026. Le sette precauzioni del corso sono usate come struttura della strategia di mitigazione [2].

4 Descrizione della pipeline agentic

4.1 Architettura della pipeline agentic

La Figura ?? rappresenta la pipeline completa di generazione video agentic. L’input vocale o testuale dell’utente viene ricevuto dal **Request Router**, che avvia in parallelo due percorsi con finalità e requisiti temporali differenti.

Il primo percorso, denominato **Instant Path**, costituisce il ramo Fast-Brain della pipeline. Il suo obiettivo non è generare la risposta sostanziale, ma ridurre immediatamente la latenza percepita. Esso utilizza clip pre-costruite, una classificazione preliminare dell’intento, il testo parziale disponibile e un insieme controllato di filler verbali e gestuali. L’output viene riprodotto nei primi secondi dell’interazione.

Il secondo percorso, denominato **Background Path**, costituisce il ramo Deep-Brain. Esso elabora la richiesta completa attraverso la pipeline RAG, genera il video principale, produce l’audio mediante TTS e applica il lip-sync. Al termine emette un *Video Ready Signal*. La figura `pipeline.jpg` rappresenta esclusivamente questo percorso di background e non l’intera pipeline.

I due percorsi convergono nello **Swap Manager**, responsabile della transizione dal filler al video finale. Lo Swap Manager deve garantire che la sostituzione avvenga senza sovrapposizioni audio, frame discontinuities o riproduzione di contenuti appartenenti a sessioni differenti.

La natura agentic del sistema deriva dal fatto che i componenti interpretano l’input, selezionano autonomamente azioni e contenuti, utilizzano servizi e modelli esterni, mantengono stato e coordinano due percorsi concorrenti. Il ciclo agentic non è limitato al solo LLM, ma comprende routing, selezione del filler, retrieval, generazione multimediale e decisione sul momento della transizione.

4.2 Ruoli, azioni e privilegi attesi

Tabella 1: Ruoli agentici e principio di least agency atteso.

Componente	Input	Output/azione	Accessi strettamente necessari
Fast-Brain	Partial transcript, categoria d'intento, estratto minimo della personalità	Filler breve, intent label, trigger da insieme finito	Output validator e TTS filler; nessun accesso diretto a FAISS, memoria persistente o voice asset
Deep-Brain	Trascrizione completa, contesto RAG, memoria di sessione	Risposta principale	Retrieval read-only, memoria di sessione, TTS main
Orchestratore	Stato dei due percorsi, output validati, segnali temporali	Fork, scheduling, timeout, fallback, stitching	Invocazione dei servizi multimediali secondo policy; nessun contenuto decisionale autonomo
Feedback Manager	Feedback esplicito e segnali impliciti	Proposta di modifica di ranking o few-shot pool	Feedback store; aggiornamenti persistenti mediati da policy e, per quelli ad alto impatto, HITL
RAG Retriever	Query del Deep-Brain	Chunk con provenienza e score	FAISS read-only durante l'inferenza
Voice Service	Testo validato e riferimento autorizzato	Audio sintetizzato	Voice embedding protetto; nessun accesso al RAG

4.3 Fast-Brain Agent

Il Fast-Brain è progettato per generare un riconoscimento contestuale entro un budget ridotto. Il prompt di sistema limita il compito a un filler di massimo 12 parole e richiede un output JSON strutturato. Il Fast-Brain non deve rispondere alla domanda, richiedere dati all'utente, dare consigli sostanziali o selezionare liberamente strumenti.

Un possibile output logico è:

Listing 1: Output logico del Fast-Brain.

```
{
  "session_id": "9f4b...",
  "intent": "complex_analytical",
  "trigger": "GAZE_UP_LEFT",
  "filler": "That is an important question; let me consider it carefully.",
  "sequence": 12
}
```

Il JSON non è un confine di sicurezza di per sé. Deve essere validato da un componente deterministico indipendente prima di raggiungere TTS e animazione.

4.4 Deep-Brain Agent

Il Deep-Brain riceve la trascrizione completa e genera la risposta principale. Il percorso può includere:

- query expansion e retrieval su indice FAISS;
- contesto RAG con metadati e provenienza;
- memoria di sessione e, se prevista, memoria persistente;

- few-shot examples e system/personality prompt;
- TTS, voice cloning e generazione video.

La memoria persistente non è assunta come scrivibile direttamente dall'utente. Qualora il feedback possa aggiornare ranking o few-shot pool, tali aggiornamenti costituiscono un'azione privileged separata dall'inferenza.

4.5 Orchestrazione e stati

L'orchestratore deve implementare una macchina a stati esplicita:

1. ricezione input e apertura della sessione;
2. fork dei due percorsi;
3. validazione del Fast-Brain;
4. emissione del filler oppure fallback statico;
5. preparazione della risposta principale;
6. transizione controllata filler-main;
7. chiusura della sessione e registrazione dell'audit trail.

La race condition “Double-Speak” non è un'elevation of privilege. È un rischio di integrità dello stato e disponibilità/qualità del servizio, da trattare tramite state machine, lock logico, idempotenza e timeout.

5 Data Flow Diagram e trust boundary

5.1 DFD di livello 0

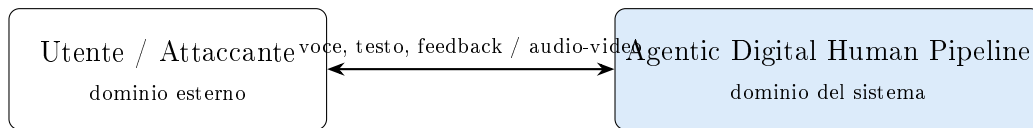


Figura 2: DFD livello 0.

5.2 DFD di livello 1

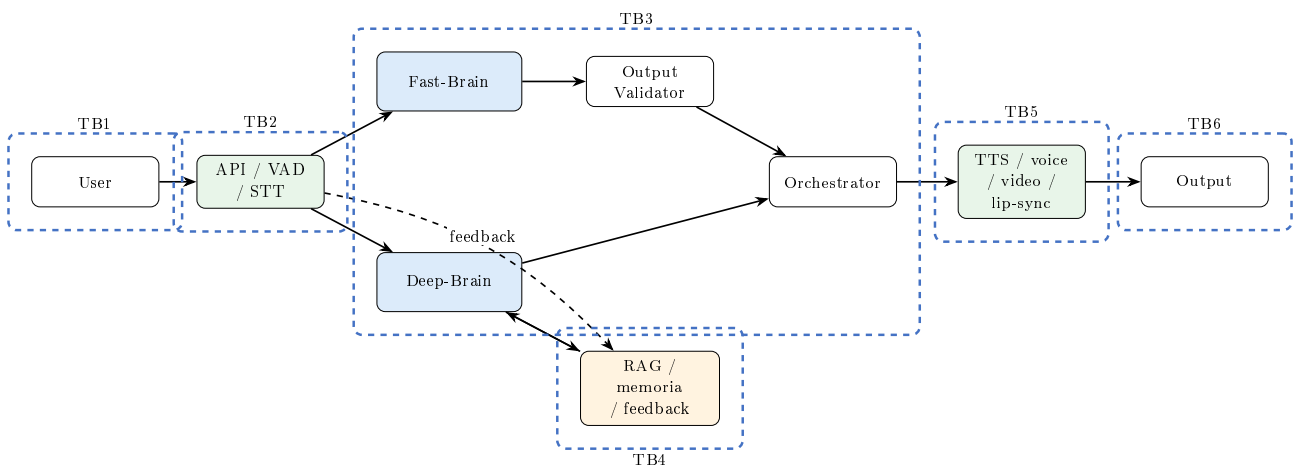


Figura 3: DFD livello 1 e principali trust boundary.

Tabella 2: Trust boundary e requisiti di sicurezza.

TB	Confine	Dati/azioni	Rischi dominanti
TB1	Utente esterno $\leftrightarrow$ edge	Voce, testo, feedback, session ID	Spoofing, prompt injection, flooding, feedback manipulation
TB2	Edge $\rightarrow$ agenti	Partial transcript, full transcript, intent preliminare	Truncation, goal hijack, PII leakage, session mix-up
TB3	Agenti $\leftrightarrow$ orchestratore	Filler, trigger, risposta, completion signal	Identity spoofing, tampering, replay, state desynchronization
TB4	Deep-Brain $\leftrightarrow$ RAG/memoria	Query, chunk, embedding, score, feedback update	Poisoning, cross-user leakage, unauthorized write
TB5	Orchestratore $\leftrightarrow$ media services	Testo, voice reference, prompt visuale, audio e video intermedi	Tool misuse, supply chain, provider disclosure, artifact tampering
TB6	Output $\rightarrow$ utente	Video, audio, metadata, provenance	Impersonazione, output tampering, assenza di disclosure AI

6 Asset Model

L’asset model identifica gli elementi della pipeline agentica che devono essere protetti e che saranno successivamente analizzati rispetto alle minacce della OWASP Top 10 for Agentic Applications 2026.

L’analisi considera l’intera pipeline: l’input vocale o testuale dell’utente, il Request Router, l’Instant Path o Fast-Brain, il Background Path o Deep-Brain, la pipeline RAG, i componenti di generazione audio e video, lo Swap Manager e il flusso multimediale finale diretto all’utente.

In accordo con le indicazioni progettuali, gli asset sono suddivisi in due categorie principali:

- **Data Assets:** dati acquisiti, prodotti, memorizzati, recuperati o trasmessi durante l’esecuzione della pipeline;
- **Model Assets:** modelli di machine learning, prompt operativi e componenti logiche che determinano o controllano il comportamento agentic del sistema.

Per ciascun asset sono indicati:

1. il ruolo svolto all’interno della pipeline;
2. la rilevanza rispetto alle categorie STRIDE-AI;
3. le proprietà di sicurezza che potrebbero essere compromesse.

6.1 Proprietà di sicurezza considerate

La metodologia considera le proprietà di sicurezza **CIA³-R**. Nel seguito viene adottata la seguente notazione:

C – Confidentiality Le informazioni devono essere accessibili esclusivamente agli utenti, agli agenti e ai servizi autorizzati.

I – Integrity Dati, configurazioni, modelli e risultati non devono essere alterati in modo accidentale o non autorizzato.

A – Availability Gli asset e i servizi devono essere disponibili nei tempi richiesti dalla pipeline, con particolare attenzione ai vincoli di latenza dell’Instant Path.

Au – Authentication Deve essere verificata l’identità degli utenti, degli agenti e dei servizi che partecipano all’elaborazione.

Az – Authorization Ogni componente deve poter accedere soltanto alle risorse ed eseguire soltanto le operazioni necessarie al proprio obiettivo.

Ac – Accountability Le operazioni devono poter essere attribuite in modo verificabile all’utente, all’agente o al servizio che le ha eseguite.

R – Non-repudiation Un soggetto o componente non deve poter negare di avere generato un messaggio, modificato un dato, invocato un servizio o autorizzato una transizione.

Le proprietà riportate nelle tabelle rappresentano le proprietà potenzialmente violate qualora l’asset venga compromesso. La loro presenza non implica che la violazione avvenga necessariamente in ogni scenario di attacco.

6.2 Data Assets

I Data Assets comprendono gli input dell’utente, le rappresentazioni testuali prodotte dallo STT, i dati RAG e di memoria, i risultati intermedi, gli artefatti audiovisivi e i dati di coordinamento necessari al funzionamento dei due percorsi concorrenti.

Tra i Data Assets sono inclusi anche i **Personality Source Artifacts**. Essi corrispondono ai file sorgente che descrivono la leggenda del personaggio, i suoi tratti caratteriali, il tono e le abitudini verbali. Tali artefatti sono distinti dai **Personality/System Prompts**, classificati tra i Model Assets: i primi sono dati persistenti utilizzati per costruire la personalità, mentre i secondi sono le istruzioni operative effettivamente fornite ai modelli durante l’inferenza.

Tabella 3: Data Assets della pipeline agentica

Asset	Descrizione	STRIDE-AI Relevance	Proprietà violata
D1 – User Audio/Input Streams	Flussi vocali o testuali prodotti dall’utente e ricevuti dalla pipeline. Comprendono il segnale audio originale, il testo inserito direttamente e i relativi metadati di sessione.	Spoofing: replay, voce sintetica o deepfake possono impersonare un utente. Tampering: audio avversariale o input modificati possono alterare la trascrizione. Information Disclosure: l’input può contenere dati personali, biometrici o sensibili. Denial of Service: input continui o sovradimensionati possono saturare VAD, STT e servizi successivi.	C, I, A, Au
D2 – Short Prompt Tokens e Partial Transcript	Primi token o frammenti della trascrizione inviati all’Instant Path per classificare preliminarmente l’intento e selezionare il filler.	Tampering: piccole modifiche possono alterare intent bucket, tono e filler selezionato. Spoofing: una trascrizione falsificata può essere attribuita all’utente. Information Disclosure: il frammento può contenere dati sensibili prima dell’elaborazione completa. Elevation of Privilege: contenuti interpretati come istruzioni possono deviare l’obiettivo del Fast-Brain.	C, I, Au, Az

Continua nella pagina successiva

Tabella 3 – continuazione

Asset	Descrizione	STRIDE-AI Relevance	Proprietà violata
D3 – Full Transcript e Normalized User Request	Trascrizione completa e normalizzata della richiesta, utilizzata dal Background Path e dal Deep-Brain per produrre la risposta principale.	Tampering: alterazioni o errori della trascrizione cambiano il significato della richiesta. Information Disclosure: il testo può contenere informazioni personali o confidenziali. Repudiation: senza correlazione con l'audio originale non è possibile dimostrare quale richiesta sia stata ricevuta. Denial of Service: richieste eccessivamente lunghe aumentano latenza, memoria e consumo di token.	C, I, A, Ac, R
D4 – RAG Knowledge Base e Context Memory	Documenti, chunk, embedding, indici vettoriali, metadati, memoria di sessione ed eventuale memoria persistente utilizzati dal Deep-Brain.	Tampering: documenti o embedding avvelenati possono introdurre informazioni false o istruzioni nascoste. Information Disclosure: retrieval non isolato può esporre dati riservati o appartenenti ad altre sessioni. Repudiation: senza provenance non è possibile identificare la fonte del contenuto recuperato. Denial of Service: query costose o crescita incontrollata dello store possono rallentare la pipeline. Elevation of Privilege: contenuti RAG malevoli possono indurre azioni o accessi fuori scope.	C, I, A, Az, Ac, R
D5 – Behavioral Animation Triggers	Output strutturati che specificano il comportamento non verbale dell'avatar, come identificatore della clip, movimento degli occhi, inclinazione della testa, gesto o stato emotivo.	Tampering: la modifica del trigger può produrre gesti non coerenti, offensivi o manipolativi. Spoofing: trigger contraffatti possono essere presentati come output legittimi del Fast-Brain. Repudiation: senza tracciamento non è possibile attribuire la selezione del gesto. Denial of Service: valori non validi possono bloccare il motore di animazione.	I, A, Au, Ac, R
D6 – Filler e Main Response Transcripts	Testo del filler generato dall'Instant Path e testo della risposta principale generato dal Deep-Brain, successivamente inviati ai componenti TTS e video.	Tampering: la modifica del testo altera ciò che l'avatar pronuncia. Information Disclosure: la risposta può esporre dati recuperati dal RAG o dalla memoria. Spoofing: un output inserito da un componente non autorizzato può apparire come risposta dell'agente. Repudiation: senza correlazione tra input, modello e output non è possibile ricostruire l'origine della risposta.	C, I, Au, Ac, R

Continua nella pagina successiva

Tabella 3 – continuazione

Asset	Descrizione	STRIDE-AI Relevance	Proprietà violata
D7 – Personality Source Artifacts	File sorgente contenenti leggenda del personaggio, tratti della personalità, tono, dialetto, abitudini verbali e regole stilistiche.	Tampering: modifiche ai file possono alterare stabilmente identità, valori e comportamento dell'avatar. Information Disclosure: gli artefatti possono rivelare le logiche interne di costruzione della persona. Spoofing: file sostitutivi possono introdurre una persona contraffatta. Repudiation: senza versionamento non è possibile stabilire chi abbia modificato la definizione del personaggio.	C, I, Au, Az, Ac, R
D8 – Voice e Visual Identity Assets	Campioni vocali, voice embedding, immagini, video di riferimento e altri materiali necessari a riprodurre l'identità audiovisiva del personaggio.	Spoofing: il furto degli asset permette di creare contenuti contraffatti attribuiti al personaggio. Tampering: alterazioni dei riferimenti possono modificare voce, volto o comportamento visivo. Information Disclosure: gli asset possono includere dati biometrici o proprietari. Denial of Service: cancellazione o indisponibilità impediscono la generazione audiovisiva.	C, I, A, Au, Az
D9 – Intermediate Audio/Video Artifacts	File e stream temporanei prodotti durante TTS, voice cloning, video generation, lip-sync, interpolazione e composizione.	Tampering: un artefatto intermedio può essere sostituito con audio o video non autorizzato. Information Disclosure: file temporanei non protetti possono esporre risposte, voce clonata o immagini. Spoofing: un artefatto contraffatto può essere accettato come output di un servizio legittimo. Denial of Service: file corrotti o mancanti possono interrompere la generazione o lo stitching.	C, I, A, Au
D10 – Coordination e Swap State	Messaggi e dati di coordinamento tra Instant Path, Background Path e Swap Manager, inclusi session ID, job ID, timestamp, stato di playback e <i>Video Ready Signal</i> .	Spoofing: un falso <i>Video Ready Signal</i> può causare uno swap prematuro. Tampering: la modifica di session ID o stato può associare contenuti appartenenti a richieste differenti. Repudiation: senza log non è possibile determinare quale componente abbia autorizzato lo swap. Denial of Service: perdita o ritardo dei segnali può bloccare la pipeline. Elevation of Privilege: un componente non autorizzato può controllare la transizione tra i due percorsi.	I, A, Au, Az, Ac, R

Continua nella pagina successiva

Tabella 3 – continuazione

Asset	Descrizione	STRIDE-AI Relevance	Proprietà violata
D11 – WebRTC Media Streams	Flusso audio-video finale trasmesso all'utente, inclusi pacchetti multimediali, identificativi e dati necessari alla negoziazione della sessione.	Spoofing: un endpoint contraffatto può impersonare il destinatario o il servizio di streaming. Tampering: pacchetti audio-video possono essere modificati o sostituiti. Information Disclosure: intercettazioni o configurazioni errate possono esporre la conversazione. Denial of Service: flooding, perdita di pacchetti o saturazione possono interrompere il flusso.	C, I, A, Au
D12 – Audit, Provenance e Feedback Data	Log di richieste, decisioni, invocazioni dei servizi, transizioni, errori, provenance degli artefatti e feedback forniti dagli utenti.	Tampering: log modificati possono nascondere errori o azioni non autorizzate. Repudiation: log incompleti impediscono l'attribuzione delle azioni. Information Disclosure: i log possono contenere prompt, output, identificatori e dati sensibili. Denial of Service: la saturazione dello storage può ridurre l'osservabilità o bloccare il sistema.	C, I, A, Az, Ac, R

6.3 Model Assets

I Model Assets comprendono i modelli utilizzati per analizzare, recuperare e generare contenuti, i prompt che ne definiscono il comportamento e la logica applicativa che coordina i due percorsi concorrenti.

La categoria è utilizzata in senso architettureale esteso. Comprende quindi non soltanto i pesi dei modelli di machine learning, ma anche prompt e componenti software che determinano obiettivi, vincoli, routing e sequenze operative del sistema agentico.

Tabella 4: Model Assets della pipeline agentica

Asset	Descrizione	STRIDE-AI Relevance	Proprietà violata
M1 – Fast-Brain Agent e Intent Classifier	Modello a bassa latenza che analizza la trascrizione parziale, classifica l'intento e seleziona il filler verbale o gestuale da riprodurre nei primi secondi.	Spoofing: un modello o endpoint contraffatto può produrre output presentati come legittimi. Tampering: pesi, configurazioni o soglie alterate modificano la classificazione dell'intento. Information Disclosure: il modello può esporre prompt o dati di configurazione. Denial of Service: rallentamenti o indisponibilità annullano il vantaggio dell'Instant Path. Elevation of Privilege: il Fast-Brain può estendere il proprio ruolo oltre la generazione del filler.	C, I, A, Au, Az
M2 – Deep-Brain Agent	LLM principale responsabile dell'interpretazione completa della richiesta, dell'utilizzo del contesto RAG e della generazione della risposta sostanziale.	Spoofing: un endpoint contraffatto può impersonare il modello principale. Tampering: pesi o configurazioni alterati possono causare risposte malevole o non allineate. Information Disclosure: il modello può rivelare dati del contesto, della memoria o delle istruzioni interne. Denial of Service: consumo non limitato può rendere indisponibile il Background Path. Elevation of Privilege: il modello può tentare di utilizzare risorse oltre l'obiettivo assegnato.	C, I, A, Au, Az
M3 – Personality/System Prompts	Istruzioni operative condivise o coordinate tra Fast-Brain e Deep-Brain per mantenere coerenza di identità, ruolo, tono, comportamento, limiti e obiettivi.	Tampering: modifiche non autorizzate possono causare goal misalignment, perdita della personalità o rimozione dei vincoli. Information Disclosure: il prompt può essere estratto mediante prompt leakage. Spoofing: un prompt contraffatto può essere caricato come configurazione ufficiale. Repudiation: senza versionamento non è possibile stabilire quale versione sia stata usata. Elevation of Privilege: istruzioni manipolate possono ampliare autonomia, accessi o funzioni dell'agente.	C, I, Au, Az, Ac, R

Continua nella pagina successiva

Tabella 4 – continuazione

Asset	Descrizione	STRIDE-AI Relevance	Proprietà violata
M4 – Embedding e Retrieval Models	Modelli e funzioni utilizzati per generare embedding, confrontare query e documenti, ordinare i risultati e selezionare il contesto inviato al Deep-Brain.	Tampering: alterazioni del modello o dei parametri possono favorire documenti malevoli o irrilevanti. Information Disclosure: attacchi agli embedding possono rivelare informazioni sui documenti indicizzati. Denial of Service: query avversariali o indici sovraccarichi possono rallentare il retrieval. Elevation of Privilege: filtri errati possono recuperare documenti fuori dallo scope autorizzato.	C, I, A, Az
M5 – VAD e Streaming STT Models	Modelli che rilevano l'attività vocale e trasformano progressivamente l'audio in partial transcript e trascrizione completa.	Spoofing: audio sintetico o replay può essere interpretato come voce autentica. Tampering: audio avversariale può alterare la trascrizione senza essere percepibile dall'utente. Information Disclosure: il servizio elabora contenuti vocali potenzialmente sensibili. Denial of Service: rumore continuo può impedire il rilevamento delle pause e bloccare il routing.	C, I, A, Au
M6 – TTS e Voice-Cloning Models	Modelli che trasformano filler e risposta principale in audio e riproducono la voce associata al personaggio.	Spoofing: il modello può generare audio falsamente attribuito al personaggio. Tampering: parametri o riferimenti vocali alterati modificano voce, tono o contenuto. Information Disclosure: il provider può esporre voice embedding, testo o audio generato. Denial of Service: indisponibilità o latenza elevata impediscono la produzione dell'audio.	C, I, A, Au, Az
M7 – Video Generation Model	Modello utilizzato dal Background Path per generare il video principale a partire dalla richiesta, dal personaggio e dagli artefatti di riferimento.	Spoofing: output contraffatti possono essere presentati come video ufficiali del personaggio. Tampering: modifiche a modello, configurazione o input possono produrre scene non autorizzate. Information Disclosure: il servizio può esporre prompt, reference media o output intermedi. Denial of Service: costo computazionale e durata rendono il modello un punto critico di disponibilità.	C, I, A, Au

Continua nella pagina successiva

Tabella 4 – continuazione

Asset	Descrizione	STRIDE-AI Relevance	Proprietà violata
M8 – Lip-Sync e Animation Models	Modelli multimodali che sincronizzano voce, movimento delle labbra, espressioni, gesti e frame del personaggio.	Tampering: la modifica dei parametri può generare comportamenti visivi errati o manipolativi. Spoofing: un modello sostitutivo può produrre animazioni presentate come legittime. Information Disclosure: accessi non autorizzati possono esporre reference media e caratteristiche del personaggio. Denial of Service: errori o indisponibilità impediscono la generazione del video finale.	C, I, A, Au
M9 – Request Router e Orchestration Logic	Codice e regole che ricevono l'input, avviano in parallelo Instant Path e Background Path, associano risultati e sessioni e gestiscono timeout, retry, code e priorità.	Spoofing: richieste o risposte provenienti da componenti contraffatti possono essere accettate come legittime. Tampering: modifiche al routing possono deviare dati, saltare controlli o associare output alla sessione errata. Repudiation: senza log non è possibile ricostruire le decisioni di routing. Denial of Service: loop, race condition o code non limitate possono bloccare entrambi i percorsi. Elevation of Privilege: un orchestratore compromesso può invocare servizi con privilegi superiori.	C, I, A, Au, Az, Ac, R
M10 – Swap Manager e Stitching Logic	Logica che decide quando terminare il filler, quando avviare il contenuto principale e come unire audio e video senza sovrapposizioni o discontinuità.	Spoofing: segnali di completamento falsi possono attivare una transizione non autorizzata. Tampering: modifiche allo stato possono causare double-speak, riproduzione di video errati o contaminazione tra sessioni. Repudiation: senza log non è possibile attribuire la decisione di transizione. Denial of Service: race condition o segnali mancanti possono bloccare il filler o interrompere il video. Elevation of Privilege: il controllo dello swap permette di scegliere quale contenuto mostrare all'utente.	I, A, Au, Az, Ac, R

6.4 Considerazioni sulla classificazione

La separazione tra Data Assets e Model Assets è basata sul ruolo prevalente dell'elemento nel sistema. I **Personality Source Artifacts** sono classificati come dati perché consistono in contenuti persistenti e versionabili utilizzati per costruire la configurazione del personaggio. I **Personality/System Prompts** sono invece classificati come Model Assets, in accordo con la classificazione fornita nella traccia, poiché costituiscono istruzioni operative che condizionano direttamente il comportamento dei modelli.

La distinzione evita una duplicazione tra i due asset:

- D7 protegge il contenuto sorgente da cui viene costruita la personalità;
- M3 protegge la formulazione operativa effettivamente inserita nel contesto dei modelli.

Il Request Router, l'Orchestration Logic e lo Swap Manager non sono modelli di machine learning in senso stretto. Sono tuttavia inclusi tra i Model Assets perché controllano il comportamento agentico complessivo, determinando routing, concorrenza, associazione tra sessioni, sequenza delle operazioni e transizione tra filler e risposta finale.

Le proprietà indicate nelle Tabelle 3 e 4 saranno utilizzate nelle sezioni successive per valutare l'applicabilità, la likelihood e la severity delle minacce OWASP rispetto a ciascun asset.

7 Identificazione delle minacce

7.1 STRIDE-AI applicato direttamente alle threat concrete

STRIDE-AI viene usato come classificatore delle minacce, non come punteggio assegnato astrattamente a ogni asset. La tabella seguente mantiene la tracciabilità fra threat, asset, proprietà, categoria STRIDE e rischio OWASP.

Tabella 5: Threat catalogue sintetico.

ID	Threat concreta	Asset	Proprietà	STRIDE / OWASP	Priorità
T1	Prompt injection nei token parziali ridefinisce il goal del Fast-Brain	D2, D4, M1	I, Authenticity	Tampering / ASI01	Alto
T2	Adversarial audio o segmentazione STT produce un partial transcript malevolo	D1–D3, M4	I, Authenticity	Tampering, Spoofing / ASI01	Alto
T3	Feedback coordinato altera ranking o few-shot pool	D5, D8, D9	I, Non-repudiation	Tampering / ASI06	Critico
T4	Il Fast-Brain usa credenziali o endpoint riservati al Deep-Brain	A1, A2, D7	Authorization	Elevation of Privilege / ASI03	Critico
T5	Replay o modifica di trigger e completion signal	D10, A4, A5	I, Authenticity	Tampering, Spoofing / ASI07	Alto
T6	Furto o uso non autorizzato del voice asset per impersonare il personaggio	D12, M6, D15	C, Authenticity	Disclosure, Spoofing / ASI03, ASI09	Critico
T7	Modello, libreria o servizio esterno compromesso	M1–M8, A7	I, C	Tampering / ASI04	Alto
T8	Flooding o input costosi saturano GPU, video path o lip-sync	M7, M8, A6	Availability	Denial of Service / ASI08	Medio

ID	Threat concreta	Asset	Proprietà	STRIDE / OWASP	Priorità
T9	Filler persuasivo richiede PII o induce l'utente ad accettare guida malevola	D10, D15, M1	Authenticity, C	Spoofing, Tampering / ASI09	Alto
T10	Fast-Brain o Deep-Brain devia stabilmente dalla policy dopo aggiornamento o prompt tampering	D4, M1, M2, A7	I, Authenticity	Tampering / ASI10	Medio
T11	Artefatti audio-video intermedi vengono sostituiti prima del lip-sync	D14, D15	I, Authenticity	Tampering / ASI02, ASI04	Alto
T12	Log incompleti impediscono di attribuire modifiche a memoria, feedback o voice asset	D9, D12, D16	Non-repudiation	Repudiation / trasversale	Medio

7.2 Applicabilità dell'OWASP Top 10 for Agentic Applications

Tabella 6: Applicabilità OWASP Agentic 2026.

ID	Rischio	Applicabilità	Motivazione nella pipeline
ASI01	Agent Goal Hijack	Alta	Il Fast-Brain riceve input utente parziale e produce un'azione comunicativa immediata
ASI02	Tool Misuse & Exploitation	Condizionata	È rilevante solo se l'agente controlla invocazione o parametri sensibili dei servizi; non basta che TTS e lip-sync esistano
ASI03	Identity & Privilege Abuse	Alta	Agenti e servizi devono avere identità e scope separati; credenziali condivise ampliano il blast radius
ASI04	Agentic Supply Chain	Alta	Modelli, framework e servizi multimediali possono provenire da terze parti
ASI05	Unexpected Code Execution	Bassa	Nello scope non sono presenti shell, code interpreter o esecuzione dinamica di output; diventa rilevante solo in estensioni future
ASI06	Memory & Context Poisoning	Alta	RAG, feedback, few-shot pool e memoria possono influenzare interazioni future
ASI07	Insecure Inter-Agent Communication	Alta	Messaggi asincroni e segnali di stato richiedono autenticità, integrità e replay protection
ASI08	Cascading Failures	Alta	I percorsi paralleli, le risorse condivise e lo stitching possono propagare errori e DoS
ASI09	Human-Agent Trust Exploitation	Alta	Voce, volto, gesti e personalità aumentano la fiducia e il potenziale di social engineering
ASI10	Rogue Agents	Media	Modello, prompt o policy possono deviare in modo persistente; il monitoraggio deve rilevare drift e regressioni

Non applicabilità motivata di ASI05. Inserire una RCE non supportata dall'architettura indebolirebbe il threat model. ASI05 deve essere rivalutato soltanto se vengono aggiunti code interpreter, plugin dinamici, script generati o uso di `eval()`.

8 Risk prioritization

8.1 Criteri

Il rischio è valutato qualitativamente come combinazione di likelihood e impact. Non viene usato RPN. La likelihood considera accessibilità del vettore, privilegi richiesti, complessità, ripetibilità e controlli esistenti. L'impact considera dati esposti, persistenza, utenti coinvolti, propagazione, perdita di autenticità, indisponibilità e danno reputazionale.

Sono inoltre considerati quattro amplificatori agentici richiamati nelle metriche AIVSS presentate nel corso [2]:

- autonomia dell'agente;
- memoria persistente;
- interazione multi-agent;
- criticità della decisione e potere persuasivo dell'output.

8.2 Matrice qualitativa

Tabella 7: Matrice likelihood $\times$ impact.

	Impact basso	Impact medio	Impact alto
Likelihood alta	Medio	Alto	Critico
Likelihood media	Basso	Medio	Alto
Likelihood bassa	Basso	Basso	Medio

8.3 Priorità dei rischi principali

Tabella 8: Valutazione dei rischi prioritari.

ID	Rischio	Lik.	Impact	Risk	Amplificatori agentici
R1	Goal hijack del Fast-Brain	Alta	Alto	Critico	Output immediato, contesto parziale, human trust
R2	Feedback poisoning persistente	Alta	Alto	Critico	Persistenza, effetto cross-session, modifica del few-shot pool
R3	Identity/privilege abuse tra agenti	Media	Alto	Alto	Multi-agent, credenziali, accesso a memoria e tool
R4	Tampering/replay inter-agent	Media	Alto	Alto	Esecuzione asincrona, state machine e correlazione sessione
R5	Voice clone abuse e trust exploitation	Media	Alto	Alto	Identità biometrica, output persuasivo, difficile attribution
R6	Supply-chain compromise	Media	Alto	Alto	Molti servizi esterni, persistenza e difficile rilevazione
R7	Cascading failure/DoS	Media	Medio	Medio	Percorsi paralleli e risorse condivise

Per evitare falsa precisione, non viene assegnato un AARS numerico in assenza del calcolatore e della formula completa utilizzati dal corso. Per i rischi R1–R5 si conserva comunque un vettore descrittivo di exploitability e impatto nella sezione successiva.

9 Scenari di minaccia prioritari

9.1 Scenario 1 — Goal hijack del Fast-Brain

Classificazione: STRIDE Tampering; OWASP ASI01, con possibile propagazione verso ASI09.

Asset: partial transcript, system/personality prompt, Fast-Brain, filler, trigger JSON.

Precondizioni: l'attaccante può inviare voce o testo; il Fast-Brain opera su input parziale; l'output viene sintetizzato prima della risposta principale.

Attack path:

1. L'attaccante inserisce nei primi token un'istruzione che tenta di ridefinire il compito del Fast-Brain.
2. Lo STT produce un partial transcript privo del contesto che seguirebbe nella frase completa.
3. Il modello interpreta l'istruzione come prioritaria rispetto al ruolo di semplice filler.
4. Viene prodotto un filler che risponde alla domanda, chiede dati sensibili o induce l'utente a compiere un'azione.
5. Il contenuto viene pronunciato prima che il Deep-Brain e i controlli del percorso principale possano correggerlo.

Impatto: compromissione dell'integrità conversazionale, social engineering, possibile disclosure di PII e perdita di fiducia.

Vettore qualitativo ispirato ad AIVSS: AV:N, AC:L, AT:N, PR:N, UI:P; C:M, I:H, A:L; autonomia media, memoria bassa, multi-agent media, trust impact alto.

Detection signals: filler interrogativi, richiesta di PII, presenza di imperativi, overlap semantico con una risposta sostanziale, trigger non coerente, violazione del limite di parole.

Controlli chiave: least agency, JSON Schema, trigger enum, content policy deterministica, PII detection, timeout e filler statico pre-approvato.

9.2 Scenario 2 — Feedback poisoning persistente

Classificazione: STRIDE Tampering e Repudiation; OWASP ASI06.

Asset: feedback esplicito/implicito, ranking, FAISS metadata, few-shot pool, audit trail.

Precondizioni: il feedback influenza ranking o selezione degli esempi; i contributi non sono sufficientemente autenticati, deduplicati o limitati.

Attack path:

1. L'attaccante crea più sessioni o account e ripete feedback positivi su risposte associate a chunk malevoli.
2. In parallelo penalizza chunk corretti tramite feedback negativo o replay.
3. Il sistema aggiorna score o promuove esempi nel few-shot pool senza una soglia robusta e senza provenienza affidabile.
4. Le query future recuperano più frequentemente contenuto manipolato.
5. Il Deep-Brain produce risposte distorte per utenti diversi dall'attaccante.

Impatto: integrità compromessa in modo persistente, effetto cross-session, difficile rollback se non esistono versioning e audit.

Vettore qualitativo: AV:N, AC:L-M, AT:N, PR:L, UI:N; C:L, I:H, A:L; autonomia media, memoria alta, multi-agent media, decision criticality media-alta.

Detection signals: burst di feedback, account correlati, distribuzioni anomale, variazioni improvvise del top- k , promozione di chunk senza evidenza sufficiente.

Controlli chiave: feedback autenticato, rate limit, anti-replay, robust aggregation, separazione fra feedback e update persistente, provenance, versioning, rollback e HITL per promozioni ad alto impatto.

9.3 Scenario 3 — Identity and privilege abuse tra agenti

Classificazione: STRIDE Elevation of Privilege e Spoofing; OWASP ASI03.

Asset: service account, API token, endpoint RAG, memoria, orchestratore.

Precondizioni: Fast-Brain e Deep-Brain condividono credenziali oppure le API non verificano lo scope dell'identità chiamante.

Attack path:

1. Il Fast-Brain viene compromesso tramite goal hijack o supply-chain compromise.
2. Il processo usa il token condiviso per invocare un endpoint riservato al Deep-Brain.
3. Legge memoria, recupera dati non necessari o propone una modifica persistente.
4. L'azione appare provenire da un'identità legittima e può non essere distinta nei log.
5. Il blast radius passa dal solo filler all'intera pipeline.

Impatto: accesso non autorizzato a memoria e contesto, possibile esfiltrazione, modifica persistente e compromissione dell'orchestratore.

Vettore qualitativo: AV:A/N, AC:M, AT:P, PR:L, UI:N; C:H, I:H, A:M; autonomia alta dopo la compromissione, memoria alta, multi-agent alta.

Detection signals: chiamate RAG dall'identità Fast-Brain, uso di scope anomali, token fuori contesto, accessi incompatibili con il ruolo.

Controlli chiave: identità distinte, token short-lived, audience e scope binding, deny-by-default, policy enforcement point, network segmentation e audit per azione cross-agent.

9.4 Scenario 4 — Tampering e replay dei messaggi inter-agent

Classificazione: STRIDE Tampering e Spoofing; OWASP ASI07.

Asset: messaggi Fast-Brain/orchestratore, trigger, sequence number, session ID, completion signal.

Precondizioni: il canale o il message bus non garantisce autenticità end-to-end, freschezza e binding alla sessione.

Attack path:

1. L'attaccante intercetta o ottiene un messaggio valido del Fast-Brain.
2. Modifica il trigger oppure reinvia il messaggio in una sessione diversa.
3. L'orchestratore verifica solo la correttezza sintattica del JSON.
4. Il messaggio viene accettato come fresco e proveniente dall'agente corretto.
5. L'avatar esegue un gesto errato, riproduce un filler non correlato o entra in uno stato inconsistente.

Impatto: corruzione dello stato, output inappropriato, race condition, potenziale cascading failure.

Vettore qualitativo: AV:A, AC:M, AT:P, PR:L, UI:N; C:L, I:H, A:M; multi-agent alta.

Detection signals: sequence duplicate, timestamp fuori finestra, session mismatch, agent ID non coerente, ordine degli stati impossibile.

Controlli chiave: mTLS o identità workload equivalente, autenticazione applicativa quando il bus persiste i messaggi, nonce/sequence, expiry, idempotency key e state machine deterministica.

9.5 Scenario 5 — Voice clone abuse e human-agent trust exploitation

Classificazione: STRIDE Spoofing e Information Disclosure; OWASP ASI03, ASI04 e ASI09.

Asset: Therapist WAV, voice embedding, credenziali TTS, personality prompt, output finale e meta-data.

Precondizioni: l'attaccante ottiene il voice asset, il relativo embedding o le credenziali del servizio di clonazione.

Attack path:

1. Il voice asset viene copiato tramite storage mal configurato, insider o provider compromesso.
2. L'attaccante genera audio nella voce dell'avatar e produce un video coerente.
3. Il contenuto usa tono, formule linguistiche e gesti associati alla personalità legittima.
4. L'utente attribuisce il messaggio al sistema autentico.
5. Il contenuto può chiedere PII, promuovere rimedi non sicuri o fornire indicazioni fraudolente.

Impatto: impersonazione highly credibile, danno reputazionale, disclosure di dati, rischio di guida dannosa e difficile attribution.

Vettore qualitativo: AV:N, AC:M, AT:P, PR:L/H, UI:A; C:H, I:H, A:L; trust impact molto alto.

Detection signals: accessi anomali al voice vault, generazioni senza sessione valida, assenza di provenance, output non associato a un audit ID.

Controlli chiave: voice vault cifrato, accesso esclusivo del voice service, credenziali temporanee, watermark/provenance, audit, revoca, disclosure chiara della natura sintetica e policy che vieta richieste di PII.

10 Controlli secondo le sette precauzioni

10.1 Precauzione 1 — Least Agency

Least Agency estende least privilege alle capacità di ragionamento, memorie, tool e azioni dell'agente [2]. Applicazioni concrete:

- il Fast-Brain può produrre soltanto filler, intent label e trigger appartenenti a una whitelist;
- il Fast-Brain non accede a FAISS, memoria persistente, feedback store, voice asset o generazione video;
- il Deep-Brain usa il RAG in read-only durante l'inferenza;
- il Feedback Manager propone aggiornamenti, ma non promuove autonomamente contenuti ad alto impatto;
- l'orchestratore applica una sequenza deterministica e non interpreta output come codice;
- ogni identità ha scope, audience e durata minima necessari.

10.2 Precauzione 2 — Guardrail deterministici e HITL

Guardrail sincroni sul Fast-Brain:

- JSON Schema strict;
- filler con lunghezza massima;
- trigger da enum;
- divieto di richieste di PII e di consigli sostanziali;
- filtro per domande, imperativi e contenuti fuori policy;
- session binding e sequence validation;
- fallback statico quando un controllo fallisce o il timeout scade.

HITL per azioni ad alto impatto:

- modifica del voice asset o del personality prompt;
- promozione persistente nel few-shot pool;
- modifica del set di trigger o delle policy;
- rilascio di nuovi modelli o provider;
- aggiornamenti permanenti dell'indice RAG;
- output in domini sensibili quando il sistema formula raccomandazioni mediche o finanziarie.

10.3 Precauzione 3 — Sandboxing e controllo granulare degli accessi

- container o runtime isolati per agenti, TTS, voice service e lip-sync;
- identità workload separate e token short-lived;
- deny-by-default su rete e file system;
- voice asset in storage dedicato, cifrato e accessibile solo al voice service;
- FAISS read-only nel serving path e update path separato;
- egress control verso provider esterni;

- quote e limiti di risorse per prevenire cascading failure.

10.4 Precauzione 4 — Audit trail completo e immutabile

L'audit trail deve registrare:

- input e transcript, con protezioni per i dati sensibili;
- partial transcript inviato al Fast-Brain;
- versione di modello, prompt, policy e schema;
- filler, trigger, risultato dei controlli e fallback;
- agent identity, tool invocation, timestamp e outcome;
- chunk RAG recuperati, score e provenance;
- feedback, deduplicazione e modifiche a ranking/few-shot;
- accessi al voice asset e generazioni del voice service;
- transizioni della state machine e timeout.

Non è necessario memorizzare ragionamenti privati completi. Per la ricostruzione dell'incidente sono sufficienti decision trace, input/output, tool call, policy decision e motivazione sintetica.

10.5 Precauzione 5 — Supply chain control

- registry approvato per modelli e container;
- firme, hash e versioni bloccate;
- SBOM per librerie, servizi e modelli;
- scansione delle dipendenze e verifica della serializzazione sicura;
- test in shadow mode prima del rilascio;
- rollback rapido di modelli, prompt e policy;
- due diligence sui provider TTS, voice e video;
- registrazione della versione di ogni componente usato per generare l'output.

10.6 Precauzione 6 — Continuous execution monitoring

Il monitoraggio deve rilevare:

- filler che risponde alla domanda o richiede dati;
- goal drift e trigger anomali;
- accessi incompatibili con il ruolo dell'agente;
- replay, session mismatch e sequence duplicate;
- burst di feedback e variazioni anomale del top- k ;
- consumo GPU, timeout, retry e loop;
- Double-Speak e transizioni di stato impossibili;
- generazioni vocali prive di sessione o audit ID;
- deviazioni persistenti dopo un aggiornamento.

Devono esistere kill-switch, circuit breaker, limiti massimi di passi e graceful degradation.

10.7 Precauzione 7 — Audit periodici ispirati ad AIVSS

Gli audit devono essere ripetuti:

- dopo ogni modifica a modello, prompt, memoria o tool;
- quando cambia il livello di autonomia;
- quando viene aggiunto un nuovo provider;
- dopo incidenti o rilevazioni di drift;
- periodicamente tramite red teaming multilingue e multimodale.

L'audit riesamina vettore d'attacco, complessità, requisiti, privilegi, interazione utente, impatto CIA e amplificatori agentici.

11 Secure architecture proposal

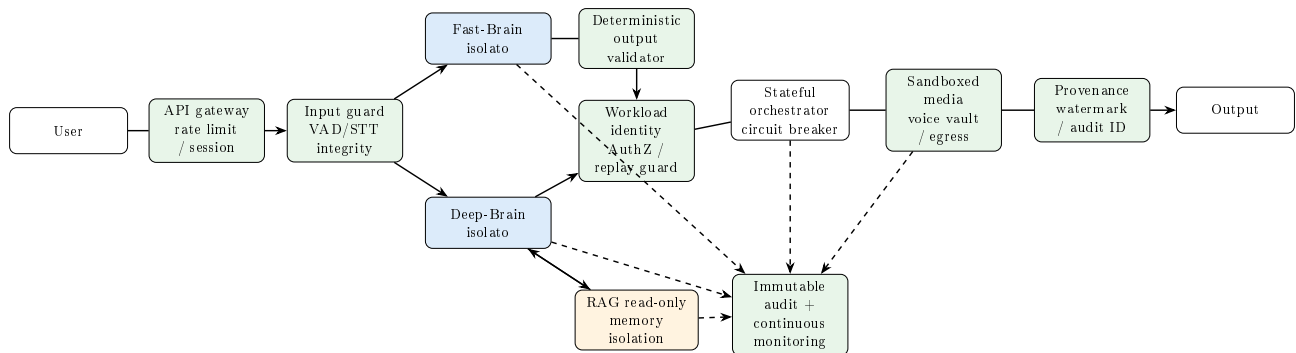


Figura 4: Secure architecture proposta.

Tabella 9: Controlli per trust boundary.

TB	Controllo	Funzione	Threat ridotte
TB1	API gateway, rate limit, session management	Limita abuso dell'input e associa ogni richiesta a un principal	T1, T2, T8, T9
TB2	Input guard e partial/full transcript correlation	Controlla formato, durata, lingua e coerenza dei transcript	T1, T2
TB3	Workload identity, AuthZ, schema, nonce e sequence	Autentica agenti e messaggi, impedisce accessi fuori ruolo e replay	T4, T5
TB4	RAG read-only, update gate, provenance e versioning	Separa serving e update, limita poisoning persistente	T3, T4, T12
TB5	Sandboxing, voice vault, egress control e signed artifacts	Limita tool misuse, furto della voce e supply-chain impact	T6, T7, T11
TB6	Provenance, watermark, audit ID e transparency disclosure	Rafforza autenticità e attribution dell'output	T6, T9, T11

11.1 Fail-safe behavior

Il sistema non deve scegliere fra sicurezza e latenza. Se il Fast-Brain non produce un output valido entro il budget, l'orchestratore usa un filler statico pre-approvato oppure mantiene un'animazione idle sicura. Non deve mai inoltrare un output non validato soltanto per rispettare il tempo target.

12 Trade-off sicurezza–latenza

I controlli sono suddivisi in base al loro posizionamento nel percorso critico.

Tabella 10: Posizionamento dei controlli.

Classe	Esempi	Posizionamento	Overhead atteso
Sincroni deterministici	JSON Schema, enum, length check, session/sequence binding, allow/deny policy	Prima del TTS filler	Trascurabile o basso; da misurare
Sincroni leggeri	PII detection, request rate limit, classificatore di policy compatto	Edge e output validator	Basso; da misurare
Asincroni	Anomaly detection, analisi feedback, correlazione dei log, drift monitoring	Fuori dal critical path	Non blocca il filler
Offline	Red teaming, scansione supply chain, AIVSS audit, model evaluation	CI/CD e audit periodico	Nessun impatto runtime

Non vengono indicati valori in millisecondi non misurati. La validazione sperimentale dovrà quantificare l’overhead reale e il tasso di attivazione del fallback.

13 Piano di validazione sperimentale

Questa sezione definisce esperimenti riproducibili. Non vengono presentati risultati empirici perché non sono ancora stati eseguiti. Le tabelle sono predisposte per essere completate dopo l’implementazione.

13.1 Esperimento A — Fast-Brain security harness

Obiettivo: verificare che il validator impedisca filler e trigger fuori policy senza introdurre un overhead incompatibile con il fast path.

Dataset:

- input benigni;
- direct prompt injection nei primi token;
- input troncati e ambigui;
- inglese, arabo standard, dialetto emiratino e code-switching;
- richieste di PII e consigli sostanziali;
- output JSON malformati o con trigger non autorizzato.

Metriche: policy violation rate, invalid JSON rate, unsafe filler rate, fallback activation rate, false positive rate e tempo di validazione.

Tabella 11: Template risultati Esperimento A.

Metrica	Baseline	Con controlli	Target/nota
Unsafe filler rate	Da misurare	Da misurare	Riduzione significativa
Invalid trigger accepted	Da misurare	Da misurare	0
False positive rate	–	Da misurare	Compatibile con UX
Validation latency	–	Da misurare	Entro il budget definito
Fallback activation rate	–	Da misurare	Monitorato, non nascosto

13.2 Esperimento B — Feedback poisoning simulation

Obiettivo: confrontare un aggiornamento diretto del ranking con un sistema protetto da autenticazione, rate limit, deduplicazione, anti-replay, robust aggregation e update gate.

Metriche: numero di feedback richiesto per portare un chunk malevolo nel top- k , percentuale di query compromesse, tempo di rilevamento e correttezza del rollback.

Tabella 12: Template risultati Esperimento B.

Metrica	Baseline	Sistema sicuro	Interpretazione
Feedback per entrare nel top- k	Da misurare	Da misurare	Più alto è migliore
Query compromesse	Da misurare	Da misurare	Più basso è migliore
Replay accettato	Da misurare	Da misurare	Target: no
Tempo di rollback	–	Da misurare	Ripristino della versione precedente

13.3 Esperimento C — Sicurezza dei messaggi inter-agent

Obiettivo: verificare il rifiuto di trigger modificati, session mismatch, duplicate sequence, messaggi scaduti e agent ID falsi.

Tabella 13: Test case dei messaggi inter-agent.

Test	Controllo atteso	Esito atteso
Trigger modificato	Schema + signature/MAC applicativo se richiesto	Rifiutato
Session ID diverso	Session binding	Rifiutato
Sequence duplicata	Replay cache / idempotency	Rifiutato
Timestamp fuori finestra	Expiry check	Rifiutato
Agent ID falso	Workload identity e authorization	Rifiutato
Filler oltre il limite	Schema e content policy	Fallback

14 Rischio residuo

Tabella 14: Valutazione qualitativa del rischio residuo atteso.

Scenario	Controlli principali	Iniziale	Residuo	Motivazione
Goal hijack Fast-Brain	Least agency, validator, fallback, monitoring	Critico	Medio	I guardrail riducono l'impatto, ma input linguistici adattivi restano possibili
Feedback poisoning	Auth feedback, update gate, robust aggregation, rollback	Critico	Medio	La persistenza è confinata e reversibile, ma Sybil sofisticati restano un rischio
Privilege abuse	Identità separate, token short-lived, policy deny-by-default	Alto	Basso-Medio	Il Fast-Brain non possiede più gli accessi utili alla propagazione
Replay inter-agent	Workload identity, nonce, sequence, expiry	Alto	Basso	Messaggi non freschi o fuori sessione vengono rifiutati
Voice clone abuse	Voice vault, provenance, audit, revoca	Alto	Medio	Un output sintetico ottenuto fuori sistema può essere difficile da eliminare completamente

Il rischio residuo deve essere rivalutato dopo la validazione sperimentale. I valori sopra rappresentano una previsione progettuale, non risultati misurati.

15 Limitazioni

- L'architettura è descritta a livello progettuale; deployment, provider e protocolli effettivi possono modificare likelihood e controlli necessari.
- Non sono stati eseguiti test empirici; la sezione di validazione contiene un piano e template di risultati.
- La valutazione del rischio è qualitativa. Non viene calcolato un AARS numerico senza lo strumento e la formula usati nel corso.
- La robustezza multilingue e dialettale dei guardrail deve essere verificata sperimentalmente.
- Il threat model non dimostra l'assenza di backdoor nei modelli; riduce il rischio tramite provenance, firme, testing e rollback.
- Privacy, compliance e consenso per voice cloning richiedono un'analisi dedicata oltre al threat model tecnico.
- L'uso dell'avatar in contesti di salute aumenta la decision criticality e richiede policy di contenuto e supervisione umana più restrittive.

16 Conclusioni

La pipeline dual-brain riduce la latenza percepita, ma introduce superfici d'attacco specifiche: il Fast-Brain agisce su input parziale, i due agenti devono coordinarsi, memorie e feedback possono persistere, e l'output audiovisivo sfrutta una forte identità umana. Il rischio non deriva soltanto dal modello linguistico, ma dall'interazione fra identità, memoria, tool, orchestrazione e fiducia dell'utente.

Il threat modeling ha mostrato come i rischi prioritari siano goal hijack, feedback poisoning, identity/privilege abuse, comunicazione inter-agent insicura e abuso della voce clonata. ASI05 è stato correttamente considerato non applicabile nello scope corrente, evitando di introdurre scenari RCE non supportati dall'architettura.

La strategia proposta applica le sette precauzioni del corso e adotta un principio centrale: **la bassa latenza non deve mai giustificare il bypass dei controlli**. I controlli deterministici restano nel fast path; monitoraggio, audit e analisi più costose operano in modo asincrono; in caso di errore il sistema usa un fallback statico sicuro. La separazione delle identità e la least agency limitano il blast radius, mentre provenance, voice vault e update gate proteggono gli asset più caratterizzanti della pipeline.

Il passo successivo è implementare il security harness e la simulazione di feedback poisoning, completando le tabelle sperimentali con valori misurati. Questo permetterà di trasformare il threat model progettuale in una valutazione verificata e riproducibile.

A JSON Schema semplificato del Fast-Brain

```
{
  "$schema": "https://json-schema.org/draft/2020-12/schema",
  "type": "object",
  "additionalProperties": false,
  "required": ["session_id", "intent", "trigger", "filler", "sequence"],
  "properties": {
    "session_id": {"type": "string", "minLength": 16, "maxLength": 128},
    "intent": {
      "type": "string",
      "enum": [
        "complex_analytical",
        "opinion_affective",
        "factual_search",
        "controversial_defensive",
        "generic_acknowledgement"
      ]
    },
    "trigger": {
      "type": "string",
      "enum": [
        "GAZE_UP_LEFT",
        "HEAD_NOD_SLIGHT",
        "LEAN_IN_BOOK",
        "HAND_GESTURE_OPEN",
        "IDLE_THINKING"
      ]
    },
    "filler": {"type": "string", "minLength": 1, "maxLength": 120},
    "sequence": {"type": "integer", "minimum": 0}
  }
}
```

```
}
```

La lunghezza in caratteri non sostituisce il controllo applicativo sul numero di parole. Il validator deve inoltre applicare content policy, PII detection e divieto di richieste all'utente.

B Formato sicuro del messaggio inter-agent

```
{
  "message_id": "uuid",
  "session_id": "9f4b...",
  "agent_id": "fast-brain-prod-eu-01",
  "audience": "orchestrator-prod-eu",
  "issued_at": "2026-07-23T14:22:18Z",
  "expires_at": "2026-07-23T14:22:20Z",
  "sequence": 12,
  "idempotency_key": "9f4b...:12",
  "payload": {
    "intent": "complex_analytical",
    "trigger": "GAZE_UP_LEFT",
    "filler": "That is an important question; let me think carefully."
  },
  "policy_version": "fastbrain-policy-3.2",
  "schema_version": "1.0"
}
```

Il trasporto deve autenticare l'identità del workload. Se il messaggio è persistito, inoltrato attraverso più trust domain o necessita di verifica end-to-end, è opportuno aggiungere una firma o un MAC applicativo. Sequence, expiry e idempotency impediscono replay e duplicazione.

C Matrice di tracciabilità

Tabella 15: Tracciabilità threat–controlli–test.

Threat	OWASP / STRIDE	Controlli	Validazione
Goal hijack	ASI01 / Tampering	Least agency, validator, fallback	Esperimento A: prompt injection multilingue
Feedback poisoning	ASI06 / Tampering	Auth, anti-replay, update gate, rollback	Esperimento B: top- <i>k</i> poisoning simulation
Privilege abuse	ASI03 / EoP	Workload identity, scoped token, AuthZ	Test negativo: Fast-Brain chiama endpoint RAG
Inter-agent replay	ASI07 / Spoofing, Tampering	Nonce, sequence, expiry, session binding	Esperimento C
Voice clone abuse	ASI09 / Spoofing, Disclosure	Voice vault, provenance, audit, revoca	Test accessi e generazioni senza audit ID

Threat	OWASP / STRIDE	Controlli	Validazione
Supply chain	ASI04 / Tampering	Firma, SBOM, scanning, shadow mode	Verifica artefatto e rollback
Cascading failure	ASI08 / DoS	Quote, timeout, circuit breaker, fallback	Load e fault-injection test

Riferimenti bibliografici

- [1] Project specification, *Agentic filler loop for a real-time digital human pipeline*, materiale fornito per il progetto, 2026.
- [2] E. Damiani, *Security Precautions for Agentic Systems: Seven Key Practices for Safe Data-Intensive Architectures*, slide del corso Sicurezza delle Architetture Data Intensive, Università degli Studi di Milano, 20 aprile 2026.
- [3] E. Damiani, *Talking Avatar with RAG Pipeline using Veo 3.1: Asset Model, Failure Modes, and Threat Analysis using STRIDE-AI*, slide del corso, 4 maggio 2026.
- [4] Project material, *The Legend of Al-Hakima Umm Saif e Core Personality Traits*, 2026.
- [5] Project material, *Verbal Habits & Response Guidelines*, 2026.
- [6] L. Mauri and E. Damiani, “STRIDE-AI: An Approach to Identifying Vulnerabilities of Machine Learning Assets,” *IEEE International Conference on Cyber Security and Resilience*, 2021.
- [7] L. Mauri and E. Damiani, “Modeling Threats to AI-ML Systems Using STRIDE,” *Sensors*, 2022.
- [8] OWASP Foundation, *OWASP Top 10 for Agentic Applications 2026*, 2026.
- [9] OWASP Foundation, *OWASP Top 10 for Large Language Model Applications 2025*, 2025.
- [10] S. Yao et al., “ReAct: Synergizing Reasoning and Acting in Language Models,” 2023.
- [11] NIST, *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*, 2023.
- [12] MITRE, *ATLAS: Adversarial Threat Landscape for Artificial-Intelligence Systems*.
- [13] IETF, *Security Architecture for WebRTC and WebRTC Security Considerations*, RFC 8827 and RFC 8826, 2021.